

Análisis de Reconocimiento & Vulnerabilidades

TARGET: scanme.nmap.org

Tipo de análisis

Fecha de análisis

Autor del informe

Clasificación

0
CRITICAL

0
HIGH

5
MEDIUM

8
LOW

17
INFO

1. Resumen Ejecutivo

El análisis de seguridad realizado sobre el objetivo **scanme.nmap.org** con metodología **BLACKBOX** ha identificado un total de **30 hallazgos de seguridad**, de los cuales **0** son de severidad alta o crítica. El nivel de riesgo global estimado es **BAJO**.

El análisis fue realizado el **11/06/2026 a las 12:18:24** y tuvo una duración de **18 segundos**.

Distribución de hallazgos por severidad:

Severidad	Cantidad	Impacto	Acción recomendada
MEDIUM	5	Exposición de datos o degradación	Planificar corrección (< 30 días)
LOW	8	Riesgo limitado o teórico	Corregir en próximo ciclo
INFO	17	Sin impacto directo	Revisar y documentar

2. Alcance y Metodología

2.1 Definición del alcance

Target	scanme.nmap.org
Tipo	DOMAIN
IPs resueltas	2600:3c01::f03c:91ff:fe18:bb2f, 45.33.32.156
Modalidad	BLACKBOX
Fecha inicio	2026-06-11 12:18:24
Fecha fin	2026-06-11 12:18:43
Duración	0:00:18.898008

2.2 Metodología

El análisis se ha realizado siguiendo un enfoque estructurado por fases, partiendo de reconocimiento pasivo (OSINT) hasta análisis activo de protocolos y búsqueda de vulnerabilidades. Las fases ejecutadas son:

Fase 1 — OSINT	WHOIS, DNS, AXFR, certificados (crt.sh), ASN/BGP
Fase 2 — Shodan	Servicios expuestos, puertos, banners, CVEs indexados
Fase 3 — Leak-Lookup	Credenciales y emails filtrados en brechas conocidas
Fase 4 — Enumeración	Subdominios, hosts activos, detección de tecnologías
Fase 5 — SSL/TLS	Protocolos, cifrados, certificado, HSTS, vulnerabilidades
Fase 6 — Cabeceras HTTP	Security headers, CSP, cookies, fugas de información
Fase 7 — CVEs	Búsqueda en NVD/NIST por productos y versiones detectadas

3. Hallazgos de Seguridad

MEDIUM — 5 hallazgo(s)

[OSINT] SPF no configurado

Descripción: No se encontró registro SPF en los TXT del dominio. Permite spoofing de email.

CVSS Score: 5.3

Mitigación: Añadir registro TXT SPF: `v=spf1 include:... -all`

[OSINT] DMARC no configurado

Descripción: No se encontró registro `_dmarc`. Sin política DMARC el dominio es vulnerable a email spoofing.

CVSS Score: 5.3

Mitigación: Añadir registro TXT en `_dmarc`: `v=DMARC1; p=reject; rua=mailto:...`

[Cabeceras HTTP] Cabecera de seguridad ausente: content-security-policy

Descripción: La cabecera `content-security-policy` no está presente en la respuesta HTTP.

CVSS Score: 6.1

Mitigación: Implementar una CSP restrictiva. Ejemplo mínimo: `default-src 'self'`

[Cabeceras HTTP] Cabecera de seguridad ausente: x-frame-options

Descripción: La cabecera `x-frame-options` no está presente en la respuesta HTTP.

CVSS Score: 6.1

Mitigación: Añadir: `X-Frame-Options: DENY` (o `SAMEORIGIN` si se necesitan iframes)

[Cabeceras HTTP] No redirige HTTP a HTTPS

Descripción: `http://scanme.nmap.org` devuelve 200 sin redirección a HTTPS.

CVSS Score: 6.5

Mitigación: Configurar redirección 301 permanente de HTTP a HTTPS.

LOW — 8 hallazgo(s)

[Cabeceras HTTP] Cabecera de seguridad ausente: x-content-type-options

Descripción: La cabecera `x-content-type-options` no está presente en la respuesta HTTP.

CVSS Score: 4.3

Mitigación: Añadir: `X-Content-Type-Options: nosniff`

[Cabeceras HTTP] Cabecera de seguridad ausente: referrer-policy

Descripción: La cabecera referrer-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Referrer-Policy: strict-origin-when-cross-origin*

[Cabeceras HTTP] Cabecera de seguridad ausente: permissions-policy

Descripción: La cabecera permissions-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Permissions-Policy: geolocation=(), microphone=(), camera=()*

[Cabeceras HTTP] Cabecera de seguridad ausente: x-xss-protection

Descripción: La cabecera x-xss-protection no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: X-XSS-Protection: 1; mode=block (legacy, pero útil en navegadores antiguos)*

[Cabeceras HTTP] Cabecera de seguridad ausente: cross-origin-embedder-policy

Descripción: La cabecera cross-origin-embedder-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Cross-Origin-Embedder-Policy: require-corp*

[Cabeceras HTTP] Cabecera de seguridad ausente: cross-origin-opener-policy

Descripción: La cabecera cross-origin-opener-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Cross-Origin-Opener-Policy: same-origin*

[Cabeceras HTTP] Cabecera de seguridad ausente: cross-origin-resource-policy

Descripción: La cabecera cross-origin-resource-policy no está presente en la respuesta HTTP.

CVSS Score: 3.1

Mitigación: *Añadir: Cross-Origin-Resource-Policy: same-origin*

[Cabeceras HTTP] Información de servidor expuesta: server: Apache/2.4.7 (Ubuntu)

Descripción: La cabecera server revela información sobre el stack tecnológico: 'Apache/2.4.7 (Ubuntu)'.

CVSS Score: 3.1

Mitigación: *Eliminar o generalizar la cabecera server en la configuración del servidor.*

INFO — 17 hallazgo(s)

[OSINT] Email expuesto en WHOIS

Descripción: Email a visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email b visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email u visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email s visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email e visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email @ visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email d visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email y visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email n visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email a visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email d visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email o visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email t visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email . visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email c visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email o visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

[OSINT] Email expuesto en WHOIS

Descripción: Email m visible en registros WHOIS públicos.

Mitigación: *Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.*

4. Análisis SSL/TLS

4.3 HSTS (HTTP Strict Transport Security)

Habilitado	No
max-age	0 segundos
includeSubDomains	No
preload	No
Cabecera completa	N/A

5. Cabeceras HTTP de Seguridad

Cabecera	Estado	Valor / Nota
content-security-policy	✗ Ausente	—
x-content-type-options	✗ Ausente	—
x-frame-options	✗ Ausente	—
referrer-policy	✗ Ausente	—
permissions-policy	✗ Ausente	—
x-xss-protection	✗ Ausente	—
cross-origin-embedder-policy	✗ Ausente	—
cross-origin-opener-policy	✗ Ausente	—
cross-origin-resource-policy	✗ Ausente	—

5.1 Fugas de información en cabeceras

Cabecera	Valor expuesto
server	Apache/2.4.7 (Ubuntu)

6. OSINT & Reconocimiento

6.1 WHOIS

Registrador	DYNADOT LLC
Organización	Super Privacy Service LTD c/o Dynadot
País	US
Creación	1999-01-18 05:00:00
Expiración	2029-01-18 05:00:00
Name Servers	ns1.linode.com, ns2.linode.com, ns3.linode.com, ns4.linode.com, ns5.linode.com
Emails WHOIS	a, b, u, s, e, @, d, y, n, a, d, o, t, ., c, o, m

6.2 Registros DNS

Tipo	Valor
A	45.33.32.156
AAAA	2600:3c01::f03c:91ff:fe18:bb2f

8. Tabla CVSS Consolidada

La siguiente tabla consolida todos los hallazgos con una puntuación CVSS asignada, ordenados por severidad descendente.

#	Hallazgo	Fase	CVSS	Severidad
1	No redirige HTTP a HTTPS	Cabeceras HTTP	6.5	MEDIUM
2	Cabecera de seguridad ausente: content-security-policy	Cabeceras HTTP	6.1	MEDIUM
3	Cabecera de seguridad ausente: x-frame-options	Cabeceras HTTP	6.1	MEDIUM
4	SPF no configurado	OSINT	5.3	MEDIUM
5	DMARC no configurado	OSINT	5.3	MEDIUM
6	Cabecera de seguridad ausente: x-content-type-options	Cabeceras HTTP	4.3	LOW
7	Cabecera de seguridad ausente: referrer-policy	Cabeceras HTTP	3.1	LOW
8	Cabecera de seguridad ausente: permissions-policy	Cabeceras HTTP	3.1	LOW
9	Cabecera de seguridad ausente: x-xss-protection	Cabeceras HTTP	3.1	LOW
10	Cabecera de seguridad ausente: cross-origin-embedder-policy	Cabeceras HTTP	3.1	LOW
11	Cabecera de seguridad ausente: cross-origin-opener-policy	Cabeceras HTTP	3.1	LOW
12	Cabecera de seguridad ausente: cross-origin-resource-policy	Cabeceras HTTP	3.1	LOW
13	Información de servidor expuesta: server: Apache/2.4.7 (Ubuntu)	Cabeceras HTTP	3.1	LOW

9. Propuestas de Mitigación

A continuación se detallan las acciones de mitigación recomendadas, priorizadas por severidad e impacto potencial.

Prioridad	Hallazgo	Acción	Plazo
Planificada	SPF no configurado	Añadir registro TXT SPF: v=spf1 include:... -all	< 30 días
Planificada	DMARC no configurado	Añadir registro TXT en _dmarc.: v=DMARC1; p=reject; rua=mailto:...	< 30 días
Planificada	Cabecera de seguridad ausente: content-security-po	Implementar una CSP restrictiva. Ejemplo mínimo: default-src 'self'	< 30 días
Planificada	Cabecera de seguridad ausente: x-frame-options	Añadir: X-Frame-Options: DENY (o SAMEORIGIN si se necesitan iframes)	< 30 días
Planificada	No redirige HTTP a HTTPS	Configurar redirección 301 permanente de HTTP a HTTPS.	< 30 días
Normal	Cabecera de seguridad ausente: x-content-type-opti	Añadir: X-Content-Type-Options: nosniff	Próximo sprint
Normal	Cabecera de seguridad ausente: referrer-policy	Añadir: Referrer-Policy: strict-origin-when-cross-origin	Próximo sprint
Normal	Cabecera de seguridad ausente: permissions-policy	Añadir: Permissions-Policy: geolocation=(), microphone=(), camera=()	Próximo sprint
Normal	Cabecera de seguridad ausente: x-xss-protection	Añadir: X-XSS-Protection: 1; mode=block (legacy, pero útil en navegadores antiguos)	Próximo sprint
Normal	Cabecera de seguridad ausente: cross-origin-embedd	Añadir: Cross-Origin-Embedder-Policy: require-corp	Próximo sprint
Normal	Cabecera de seguridad ausente: cross-origin-opener	Añadir: Cross-Origin-Opener-Policy: same-origin	Próximo sprint
Normal	Cabecera de seguridad ausente: cross-origin-resour	Añadir: Cross-Origin-Resource-Policy: same-origin	Próximo sprint
Normal	Información de servidor expuesta: server: Apache/2	Eliminar o generalizar la cabecera server en la configuración del servidor.	Próximo sprint
Opcional	Email expuesto en WHOIS	Considerar privacidad WHOIS (WHOIS privacy protection) con el registrador.	Sin urgencia

Informe generado por recon-cli el 11/06/2026 a las 12:18:24. Este documento es confidencial y está destinado exclusivamente al equipo de seguridad autorizado.